

RED TEAMER

THE **CAREER** PATH

From initial access to full domain compromise. 45 pages of real salary data, adversary simulation frameworks, C2 architecture, certification roadmaps, and a battle-tested action plan for offensive security professionals.

ROLE FAMILY

Red Team Operations

SALARY RANGE

\$130K - \$280K+

MARKET GROWTH

+32% by 2032

AI DISRUPTION

Very Low Risk

A / THE ROLE

How to Use This Guide	3
What Is a Red Teamer?	4
A Day in the Life: Junior Red Teamer	5
A Day in the Life: Senior Red Team Lead	6
Red Team vs Penetration Testing	7

B / CAREER PROGRESSION

Career Progression Overview	8
Stage 1: Breaking In (0 to 2 Years)	9
Stage 2: Junior Operator (2 to 4 Years)	10
Stage 3: Mid-Level Operator (4 to 6 Years)	11
Stage 4: Senior Operator / Team Lead (6 to 9 Years)	12
Stage 5: Principal / Red Team Director (9+ Years)	13

C / TECHNICAL SKILLS

Skills Heatmap Overview	14
Active Directory Attack Paths	15
C2 Frameworks and Infrastructure	16
MITRE ATT&CK for Red Teamers	17
Evasion and Defense Bypass	18
Initial Access Tradecraft	19
Cloud Attack Paths	20
Exploit Development Fundamentals	21
Physical Security and Social Engineering	22
Purple Teaming and Reporting	23

D / CERTIFICATIONS

Certification Roadmap	24
OSCP, OSEP, and OSED Deep Dive	25
CRTO, CRTP, and GXPN	26
Building a Red Team Home Lab	27

E / TOOLS AND RESOURCES

Essential Tools by Category	28
Books, Podcasts, and Learning	29
Conferences and Community	30

F / INDUSTRY PATHS

Finance and Banking Red Teams	31
Government, Military, and Intelligence	32
Consulting and Boutique Firms	33

G / JOB SEARCH

Resume Building for Red Teamers	34
LinkedIn and Online Presence	35
Interview Prep: Technical	36
Interview Prep: Behavioral	37
Salary Negotiation Tactics	38
Real Job Postings Analyzed	39

H / MARKET AND TRENDS

Global Salary and Compensation Map	40
AI Impact on Red Teaming	41
Job Market Outlook	42

I / SUSTAINABILITY

Managing Burnout and Operator Fatigue	43
Your First 90 Days Action Plan	44

J / ABOUT

About HADESS	45
--------------	----

How to Use This Guide

This report is built for practitioners, not spectators. Whether you are breaking into offensive security for the first time or already running adversary simulations for a Fortune 500 company, every page maps directly to something you can act on this week.

Who This Guide Is For

Newcomers

Pentesting or SOC analysts looking to specialize in adversary simulation and red team operations

Operators

Working red teamers who want to level up their tradecraft, negotiate better comp, or move into leadership

Leaders

Managers building or scaling a red team program who need to benchmark salaries, hiring, and tooling

How Each Section Works

SECTION	WHAT YOU GET	BEST FOR
A. The Role	Daily workflows, archetypes, red team vs pentest comparison	Understanding what the job actually looks like
B. Career Progression	Five stages from junior to principal with salary bands and milestones	Knowing what to aim for and when
C. Technical Skills	AD attack chains, C2 frameworks, evasion, cloud, exploit dev	Identifying and closing skill gaps
D. Certifications	OSCP, OSEP, OSED, CRT0, CRTP, GXPN comparisons and ROI	Choosing certifications that actually get you hired
E. Tools	C2 frameworks, books, podcasts, communities	Building your toolkit and staying current
F. Industry Paths	Finance, government, consulting breakdown	Picking the right sector for your goals
G. Job Search	Resume, interviews, negotiation, 5 real postings analyzed	Landing and maximizing your next offer
H. Market	Global comp data, AI impact, market outlook	Understanding where the field is heading
I. Sustainability	Burnout management, 90-day onboarding plan	Building a career that lasts

Data Sources

Salary data comes from Levels.fyi, Glassdoor, and direct job postings from companies including Google, Microsoft, CrowdStrike, Meta, and Goldman Sachs. Job market projections use BLS data and CyberSeek analytics. All figures reflect Q1 2026 market conditions.

Ready to start?

Get your personalized red team career assessment at career.hadess.io

Start Now →

What Is a Red Teamer?

A red teamer is an offensive security professional who simulates real adversaries to test an organization's defenses end to end. Unlike penetration testers who focus on finding vulnerabilities in a defined scope, red teamers operate with a mission objective: breach the target, move laterally, access the crown jewels, and do it all without getting caught.

The role traces its roots to Cold War military exercises where dedicated teams played the enemy force. Today's red teamers carry that same mindset into corporate networks, cloud environments, and physical facilities. They think like attackers because they need to find the gaps that automated tools and compliance checklists miss.

Core Responsibilities

- **Adversary Simulation:** Planning and executing full-scope attack campaigns that mirror the TTPs of real threat actors like APT29, FIN7, or Lazarus Group
- **Initial Access:** Crafting phishing payloads, finding exposed services, or physically accessing facilities to establish a foothold
- **Post-Exploitation:** Moving laterally through Active Directory environments, escalating privileges, and maintaining persistent access
- **Evasion:** Bypassing EDR, antivirus, network monitoring, and email security gateways without triggering alerts
- **C2 Operations:** Deploying and managing command and control infrastructure to maintain communication with implants
- **Reporting:** Translating technical attack chains into business risk narratives that CISOs and boards can act on
- **Purple Teaming:** Working with defensive teams to validate that detections work against specific attack techniques

Key Metrics Red Teamers Care About

MTTD

Mean time to detect. How long before the SOC notices your activity? Industry average is 21 days.

TTP Coverage

What percentage of MITRE ATT&CK techniques can the org detect and respond to?

Objective Rate

How often does the red team achieve the stated campaign objective? Top teams hit 80% or higher.

The Mindset Shift

Most security professionals spend their careers defending. Red teamers flip that perspective entirely. You stop asking "how do I protect this?" and start asking "how do I break this?" That mindset shift is what makes the transition hard for many people, but it is also what makes the work deeply rewarding. You learn to see networks the way adversaries see them, and that understanding makes you more valuable than any scanner output ever could.

Think like an adversary

Build your offensive security career roadmap at career.hadess.io

Explore →

A Day in the Life: Junior Red Teamer

This is what a typical day looks like for a junior red teamer working on a two-week engagement for a financial services client. You are three days into the operation and have established initial access through a phishing campaign.

TIME	ACTIVITY	DETAILS
08:30	Morning standup	Check in with the team lead. Review overnight C2 callbacks. Your Sliver beacon on the marketing workstation checked in 14 times. No alerts fired on the client SOC dashboard.
09:00	Recon and enumeration	Run BloodHound collection from your foothold. Map the Active Directory environment: trusts, group memberships, Kerberoastable accounts. You find three service accounts with SPNs.
10:00	Kerberoasting	Request TGS tickets for the service accounts. Export the hashes. Start cracking with hashcat on your GPU rig. Two accounts crack within 20 minutes, both using Password2024! variations.
11:00	Lateral movement	Use the cracked service account to access a file server. Find a PowerShell script with hardcoded database credentials. Document everything with timestamps and screenshots for the report.
12:00	Lunch break	Catch up on the latest SpecterOps blog post about ADCS abuse. Take notes for the afternoon.
13:00	ADCS enumeration	Run Certify to check for vulnerable certificate templates. Find an ESC1 misconfiguration that lets you request a certificate as any domain user. Flag this for the lead.
14:00	Payload development	The lead asks you to prepare a backup payload in case the primary C2 channel gets burned. You build a new Sliver implant with different sleep times and a new redirector domain.
15:30	Documentation	Update the engagement tracker with all findings. Add attack chain diagrams showing how you moved from phishing to service account compromise.
16:30	Purple team sync	Quick 30-minute call with the client's detection team. Walk them through the morning's Kerberoasting activity and help them write a Splunk query to catch it next time.
17:00	Lab time	Spend an hour in the team's lab environment testing a new AMSI bypass technique before deploying it on the live engagement tomorrow.

What Makes This Role Different from Pentesting

Notice the pacing. A pentest might have you running Nessus scans and writing findings all day. Red teaming is slower, more deliberate. You are not trying to find every vulnerability; you are trying to achieve a specific objective without getting caught. The stealth requirement changes everything about how you work.

Start your offensive journey

Get matched with red team roles at [career.hadess.io](#)

Get Started →

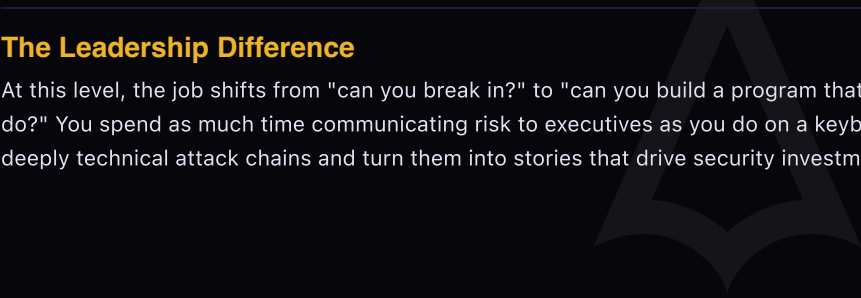
A Day in the Life: Senior Red Team Lead

You are leading a three-person red team at a large technology company. The team runs continuous adversary simulations against production infrastructure. Today you are managing two concurrent operations and preparing a board briefing.

TIME	ACTIVITY	DETAILS
07:30	Threat intel review	Check the morning brief from the CTI team. A new ransomware group is targeting your industry using compromised VPN appliances. You start scoping a simulation based on their TTPs.
08:30	Operator check-in	Review both active operations. Operation 1: junior operator achieved domain admin last night via a golden ticket. Operation 2: mid-level operator is stuck trying to bypass CrowdStrike on a server. You suggest using a direct syscall approach.
09:30	C2 infrastructure	Review the team's infrastructure. Rotate two domains that have been active for 30 days. Stand up a new redirector on Azure using Terraform. Update the team's domain categorization tracker.
10:30	CISO briefing prep	Build the quarterly red team report. Translate attack chains into business impact: "We accessed the M&A database containing \$2B in pending deals through a three-step attack that started with a phishing email to legal."
12:00	Lunch and mentoring	Grab lunch with the junior operator. Walk through ADCS attack techniques on the whiteboard. Help them understand why ESC8 is harder to exploit than ESC1 but has a bigger payoff.
13:00	Board briefing	Present to the CISO and two board members. Focus on three critical findings and their remediation status. Avoid jargon. Use the attack chain diagrams to show how a phishing email led to financial data access in under 48 hours.
14:30	Purple team workshop	Run a two-hour session with the detection engineering team. Replay the golden ticket attack in the lab and help them build a detection for anomalous TGT lifetimes in Microsoft Sentinel.
16:30	Tool development	Work on the team's custom BOF (Beacon Object File) for credential harvesting that avoids the signatures most EDR vendors flag. Test against the latest CrowdStrike and Defender ATP builds.
17:30	Hiring review	Review three resumes for an open operator position. One candidate has OSEP and CRT0 with consulting experience. Schedule them for a hands-on lab interview.

The Leadership Difference

At this level, the job shifts from "can you break in?" to "can you build a program that consistently finds blind spots before real adversaries do?" You spend as much time communicating risk to executives as you do on a keyboard. The best red team leads are translators: they take deeply technical attack chains and turn them into stories that drive security investment.



Ready to lead?

Explore red team leadership roles at career.hadess.io

Explore →

Red Team vs Penetration Testing

People use "red team" and "pentest" interchangeably, but they are fundamentally different disciplines. Understanding the distinction matters because it affects your career path, the skills you build, and the kind of work you will do day to day.

DIMENSION	PENETRATION TESTING	RED TEAMING
Objective	Find as many vulnerabilities as possible within scope	Achieve a specific mission goal (e.g., access CEO email, exfiltrate customer data)
Scope	Defined and narrow (e.g., "test this web app")	Broad and realistic (e.g., "breach us like APT29 would")
Duration	1 to 3 weeks typical	2 to 8 weeks, sometimes continuous
Stealth	Not required. The SOC usually knows you are testing.	Critical. The SOC should not know you are operating.
Social Engineering	Usually out of scope	Core tactic. Phishing, vishing, physical access.
Reporting	Vulnerability list with severity ratings	Attack narrative showing full kill chain and business impact
Team Size	1 to 2 testers	2 to 5 operators with specialized roles
Tools	Burp Suite, Nmap, Nessus, Metasploit	Custom C2, Cobalt Strike, Sliver, custom loaders and implants
Entry Salary	\$85K to \$120K	\$120K to \$160K
Career Ceiling	\$160K to \$200K as principal	\$220K to \$280K+ as director or principal

When Organizations Need Red Teams vs Pentests

Choose a Pentest When

- You need to meet compliance requirements (PCI DSS, SOC 2)
- You want a comprehensive vulnerability inventory
- Your security program is still maturing
- Budget is limited and you need quick results
- You are testing a specific application before launch

Choose a Red Team When

- You want to test your detection and response capabilities
- You need to validate your SOC against realistic threats
- You have a mature security program and want to stress test it
- You are preparing for a regulatory framework like TIBER-EU or CBEST
- Your board wants to understand real-world attack impact

The Career Transition

Most red teamers start in penetration testing and make the jump after 2 to 4 years. The transition is not just about learning new tools. You need to develop patience (operations can last weeks), stealth discipline (every command you run could burn the engagement), and communication skills (your findings only matter if leadership acts on them). The operators who make this transition successfully are the ones who treat red teaming as a craft, not just a collection of exploits.

Make the transition

Plan your move from pentesting to red teaming at career.hadess.io

Plan Now →

Career Progression Overview

Red teaming is one of the highest-paying specializations in cybersecurity, but the path is steep. Unlike generalist security roles, you cannot shortcut your way in with certifications alone. Employers want demonstrated ability to break into things, and that takes years of hands-on practice.



Salary Benchmarks by Seniority (US Market, 2026)

LEVEL	BASE SALARY	TOTAL COMP (WITH EQUITY/BONUS)	TYPICAL TITLES
Entry / Junior	\$85K - \$120K	\$95K - \$140K	Junior Penetration Tester, Associate Red Teamer
Junior Operator	\$120K - \$160K	\$140K - \$190K	Red Team Operator, Offensive Security Engineer
Mid-Level	\$160K - \$210K	\$190K - \$260K	Senior Red Team Operator, Red Team Consultant
Senior / Lead	\$200K - \$260K	\$250K - \$340K	Red Team Lead, Principal Offensive Engineer
Director / Principal	\$250K - \$350K+	\$350K - \$500K+	Director of Red Team, VP Adversary Simulation

Note on total comp: At FAANG companies and large financial institutions, equity and bonuses can add 40% to 80% on top of base salary. A senior red team lead at Google or Meta with L6/E6 leveling can realistically earn \$400K or more in total compensation.

Know your market value

Get personalized salary benchmarks at [career.hadess.io](#)

Benchmark →

Stage 1: Breaking In (0 to 2 Years)

Almost nobody starts directly in red teaming. You need foundational skills in networking, system administration, and security operations before you can credibly simulate advanced threat actors. The most common entry points are SOC analyst roles, IT help desk, system administration, or junior penetration testing.

Where People Come From

40%

Start in SOC / security operations and transition to offensive work after learning what defenders look for

30%

Come from IT administration or networking and bring deep knowledge of how systems actually work in production

30%

Enter through penetration testing, bug bounty, or CTF competitions and level up into full-scope red teaming

Skills to Build in This Phase

SKILL AREA	WHAT TO LEARN	HOW TO PRACTICE
Networking	TCP/IP, DNS, HTTP, TLS, proxy protocols, VPN internals	Build a home lab with pfSense, Wireshark packet captures, HackTheBox Prolabs
Windows Internals	Processes, services, registry, WMI, COM, scheduled tasks, Group Policy	Set up an Active Directory lab with 2 DCs and 5 workstations. Break it.
Linux	Bash scripting, process management, privilege escalation, cron, systemd	TryHackMe Linux rooms, OverTheWire Bandit and Narnia wargames
Programming	Python for tooling, PowerShell for AD, C/C# for payload development	Write your own port scanner, keylogger, and reverse shell from scratch
Web Application	OWASP Top 10, Burp Suite, SQL injection, XSS, authentication bypasses	PortSwigger Web Security Academy (free), OWASP Juice Shop

Certifications for This Stage

CompTIA Security+

eJPT (eLearnSecurity)

CompTIA Pentest+

PNPT (TCM Security)

Realistic Timeline

Plan on 12 to 24 months in a foundational role before applying for your first offensive security position. During this time, you should be spending 5 to 10 hours per week on self-study, CTFs, and lab work. The people who break in fastest are the ones who can show demonstrable skills through HackTheBox rankings, CTF placements, or a blog where they write up their methodology.

Red Flags That Slow Your Progress

- Collecting certifications without building hands-on skills
- Only using automated tools without understanding what they do underneath
- Skipping the fundamentals (networking, OS internals) to jump straight to exploit dev
- Not documenting your learning or building a portfolio

Start building your foundation

Get a personalized learning path at [career.hadess.io](#)

Start →

Stage 2: Junior Operator (2 to 4 Years)

This is where you start doing real red team work. You are on engagements, running tools, and executing attack chains under the guidance of a senior operator. Your main job is to execute the plan reliably while learning the judgment calls that separate good operators from great ones.

What You Are Expected to Do

- Execute assigned phases of an engagement (recon, initial access, lateral movement) with supervision
- Operate C2 frameworks (Cobalt Strike, Sliver, or Brute Ratel) and manage your implants without burning the operation
- Run Active Directory enumeration and exploitation tools (BloodHound, Rubeus, Certify, Impacket)
- Craft phishing payloads that bypass email security gateways and endpoint protection
- Write clear, detailed notes during operations so the lead can build the final report
- Participate in purple team exercises and explain your attack techniques to defenders

Skills You Need to Develop

SKILL	PROFICIENCY TARGET	HOW YOU WILL USE IT
Active Directory	Strong	Kerberoasting, AS-REP roasting, delegation abuse, trust exploitation, ADCS attacks
C2 Operations	Strong	Deploying listeners, managing beacons, using sleep/jitter, pivoting through networks
Phishing	Strong	Payload creation (ISO, LNK, HTA, OneNote), infrastructure setup, pretext development
Evasion Basics	Growing	AMSI bypass, ETW patching, basic process injection, sleep obfuscation
Cloud (AWS/Azure)	Growing	Enumerating IAM, abusing managed identities, Azure AD token manipulation
Report Writing	Growing	Attack chain documentation, evidence collection, writing findings with business impact

Certifications for This Stage

- OSCP (OffSec)
- CRTP (Altered Security)
- CRT0 (Zero-Point Security)

Common Mistakes at This Stage

- **Running before walking:** Trying to write custom implants when you have not mastered the basics of the tools your team already uses
- **Noisy operations:** Running SharpHound collection on every domain controller at once instead of being surgical about your enumeration
- **Poor OPSEC:** Leaving tools on disk, not cleaning up artifacts, using default Cobalt Strike profiles that get flagged immediately
- **Not asking questions:** Senior operators expect questions. They worry more when juniors go silent and start making assumptions.

Level up your operations

Connect with offensive security mentors at career.hadess.io

Connect →

Stage 3: Mid-Level Operator (4 to 6 Years)

At this level, you run engagements independently and start developing your own tradecraft. You can take an engagement from scoping to final report delivery without constant supervision. You are building tooling, mentoring juniors, and starting to think about program-level impact, not just individual operations.

What Changes at This Level

- You plan and execute full-scope operations with minimal guidance from leadership
- You develop custom tooling: loaders, payload delivery mechanisms, BOFs, process injection techniques
- You mentor junior operators during engagements and review their work
- You start building relationships with detection teams and driving purple team improvements
- You handle client communication directly, including scoping calls and finding walkthroughs
- You contribute to internal knowledge bases, playbooks, and technique documentation

Technical Depth Required

DOMAIN	WHAT YOU SHOULD KNOW
AD Exploitation	Shadow Credentials, RBCD abuse, ADCS (ESC1 through ESC8), cross-forest attacks, PAM trust abuse, LAPS bypass
Evasion	Custom shellcode loaders, syscall stubs (direct and indirect), unhooking ntdll, ETW and AMSI patching, sleep obfuscation, stack spoofing
C2 Customization	Malleable C2 profiles, domain fronting alternatives, named pipe pivoting, traffic shaping to blend with normal traffic
Cloud Attacks	Azure AD token replay, AWS role chaining, GCP service account impersonation, cross-tenant attacks
Infrastructure	Automated C2 deployment with Terraform, redirector chains, domain aging and categorization, certificate management

Certifications for This Stage

- OSEP (OffSec)
- CRT0 II (Zero-Point Security)
- GXPN (GIAC)
- CRTL (Altered Security)

Salary Expectations

\$160K

Base salary floor at consulting firms and mid-market companies

\$210K

Base salary ceiling at large tech companies and financial institutions

\$260K

Total compensation ceiling including equity and bonuses at top-tier employers

Sharpen your tradecraft

Advanced red team career guidance at [career.hadess.io](#)

Level Up →

Stage 4: Senior Operator / Team Lead (6 to 9 Years)

The senior level is where the career forks. Some people stay deeply technical and become subject matter experts in specific areas like exploit development or cloud attack research. Others move into team leadership, managing operators and building programs. Both paths pay well, but they look very different day to day.

The Technical Track

- Deep research into new attack surfaces: ADCS, Azure AD, container escapes, CI/CD pipelines
- Developing novel exploitation techniques and publishing at conferences like DEF CON, Black Hat, or BlueHat
- Building custom C2 frameworks or implants tailored to your team's needs
- Conducting assumed breach exercises against hardened environments with mature detection capabilities
- Advising product security teams on attack surface reduction based on what you see in the field

The Leadership Track

- Managing a team of 3 to 8 operators across multiple concurrent engagements
- Setting team strategy: which threat actors to emulate, which techniques to prioritize, how to measure program effectiveness
- Presenting findings to CISOs, VPs, and board members in language they understand
- Hiring, mentoring, and career development for operators on your team
- Managing budgets for tooling, infrastructure, and training
- Building relationships with peer teams: threat intel, detection engineering, incident response

Compensation at This Level

EMPLOYER TYPE	BASE SALARY	TOTAL COMP	NOTES
Consulting Firm	\$190K – \$230K	\$220K – \$280K	Plus utilization bonuses and travel per diem
Large Enterprise	\$200K – \$250K	\$260K – \$340K	Internal red team with RSU packages
FAANG / Big Tech	\$220K – \$260K	\$350K – \$450K	L6/E6 leveling with significant equity
Financial Services	\$210K – \$260K	\$280K – \$380K	Banks, hedge funds, trading firms with cash bonuses

Key Certifications

- OSED (OffSec)
- OSCE3 (OffSec)
- GXPn (GIAC)
- CREST CRT

Ready to lead a team?

Explore red team leadership positions at [career.hadess.io](#)

Explore →

Stage 5: Principal / Red Team Director (9+ Years)

At this level, you are shaping how an entire organization thinks about adversary simulation. You define the red team's charter, hire and develop the team, influence security strategy at the executive level, and often serve as the bridge between technical security and business risk management.

What the Role Looks Like

- Setting the strategic direction for the red team program: objectives, threat models, engagement cadence
- Building relationships with C-suite and board members to translate red team findings into security investment decisions
- Defining metrics that measure program effectiveness: detection coverage improvements, mean time to detect trends, remediation velocity
- Representing the organization at industry events, regulatory discussions, and peer sharing groups (FS-ISAC, FIRST)
- Managing multi-million dollar budgets for personnel, tooling, licensing, and infrastructure
- Staying technically relevant by participating in select engagements and reviewing high-impact findings

Alternative Paths at This Level

PATH	DESCRIPTION	COMPENSATION RANGE
VP of Red Team / Adversary Simulation	Run the red team program for a Fortune 500 or large financial institution. Report to the CISO.	\$300K – \$500K+ TC
Distinguished Engineer (Offensive)	Deep technical IC role at big tech. Research novel attack techniques, build internal tooling, publish at top venues.	\$450K – \$700K+ TC
CISO	Some red team leaders transition to CISO roles, bringing offensive perspective to defense strategy.	\$350K – \$600K+ TC
Founder / Consulting	Start your own offensive security firm. High risk, high reward. Top boutique firm partners clear \$500K+.	\$200K – \$1M+ variable
Vulnerability Research	Join a government research lab, vendor vuln research team, or bug bounty full-time.	\$250K – \$500K+ TC

What Sets This Level Apart

At the director level, your impact is measured in program outcomes, not individual techniques. Did the red team's work lead to a \$5M investment in identity security? Did your findings drive a board decision to restructure the IT org? Did your program reduce the company's mean time to detect from 21 days to 3? These are the questions that matter. The best leaders at this level maintain enough technical depth to earn their team's respect while spending most of their energy on strategy, communication, and organizational influence.

Shape the future of offensive security

Connect with red team leadership opportunities at career.hadess.io

Connect →

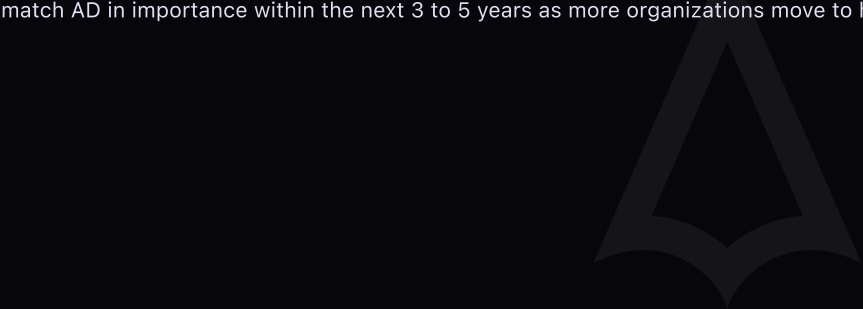
Skills Heatmap Overview

This heatmap shows which skills matter most at each career stage. Green means it is critical for that level, yellow means you should be developing it, and the bar shows overall demand in 2026 job postings.

SKILL	JUNIOR	MID	SENIOR	PRINCIPAL	DEMAND
Active Directory Attacks	Learn	Core	Core	Core	95%
C2 Frameworks	Learn	Core	Core	Core	92%
Evasion / AV Bypass	Aware	Learn	Core	Core	90%
Phishing / Social Engineering	Core	Core	Core	Lead	85%
Cloud (AWS/Azure/GCP)	Aware	Learn	Core	Core	88%
Exploit Development	Aware	Aware	Learn	Core	55%
MITRE ATT&CK	Learn	Core	Core	Core	82%
Programming (C/C#/Python)	Learn	Core	Core	Core	80%
Network Protocols	Core	Core	Core	Lead	75%
Physical Security / SE	Aware	Learn	Core	Lead	45%
Report Writing	Learn	Core	Core	Core	78%
Executive Communication	Aware	Aware	Learn	Core	60%

Key Takeaway

Active Directory and C2 operations dominate the skill requirements at every level. If you invest in one area early, make it AD. Every major enterprise runs Active Directory, and nearly every red team engagement involves AD attack paths. Cloud skills are growing fast and will likely match AD in importance within the next 3 to 5 years as more organizations move to hybrid and cloud-native architectures.



Identify your skill gaps

Take the red team skills assessment at career.hadess.io

Assess →

Active Directory Attack Paths

Active Directory is the backbone of enterprise identity. It is also the single most exploited technology in red team engagements. Understanding AD attack paths is not optional for a red teamer. It is the skill that will define your effectiveness on most operations.

The AD Kill Chain



Top AD Attack Techniques (2026)

TECHNIQUE	ATT&CK ID	TOOLS	DETECTION DIFFICULTY
Kerberoasting	T1558.003	Rubeus, Impacket GetUserSPNs	Medium
AS-REP Roasting	T1558.004	Rubeus, GetNPUsers.py	Medium
ADCS Abuse (ESC1-ESC8)	T1649	Certify, Certipy, ForgeCert	Hard
Constrained Delegation	T1134.001	Rubeus, Impacket getST	Hard
Shadow Credentials	T1556.007	Whisker, pyWhisker	Hard
DCSync	T1003.006	Mimikatz, Impacket secretsdump	Medium
Golden Ticket	T1558.001	Mimikatz, Rubeus	Hard
RBCD Abuse	T1134	Rubeus, StandIn	Hard
Group Policy Abuse	T1484.001	SharpGPOAbuse, pyGPOAbuse	Medium
LAPS Bypass	T1555	LAPSToolkit, CrackMapExec	Medium

Why ADCS Is the Biggest AD Threat in 2026

Active Directory Certificate Services has become the single most impactful attack surface in enterprise AD environments. The research published by SpecterOps in 2021 ("Certified Pre-Owned") opened the floodgates, and since then the community has found eight distinct escalation paths (ESC1 through ESC8). Most organizations still have not audited their certificate templates, and many have ESC1 or ESC4 misconfigurations that allow any authenticated user to impersonate any other user in the domain, including domain admins. If you learn one AD attack technique deeply, make it ADCS.

Master AD attack paths
Get hands-on AD lab recommendations at [career.hadess.io](#)

[Learn More →](#)

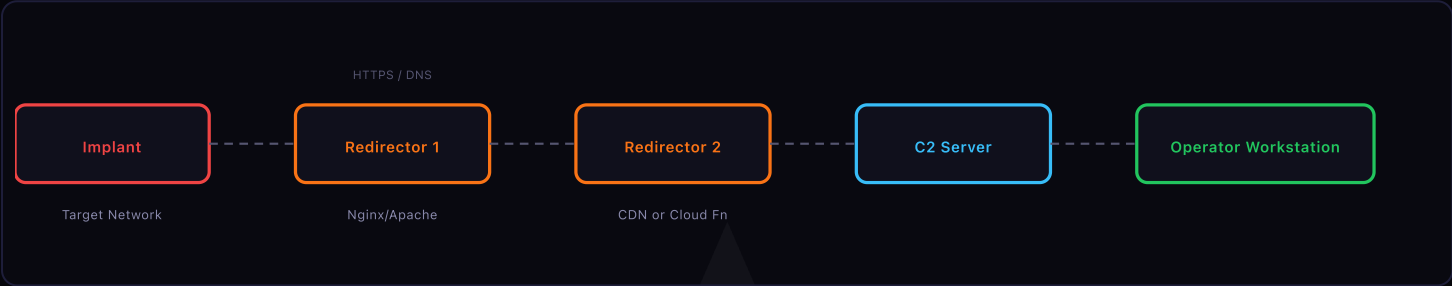
C2 Frameworks and Infrastructure

Command and control is the nervous system of any red team operation. Your C2 framework is how you communicate with implants, issue commands, move laterally, and exfiltrate data. Choosing the right framework and building resilient infrastructure separates amateur operations from professional ones.

Major C2 Frameworks (2026)

FRAMEWORK	LANGUAGE	LICENSE	BEST FOR	EDR EVASION
Cobalt Strike	Java/C	Commercial (\$5,900/yr)	Industry standard, mature ecosystem, BOF support	Moderate
Brute Ratel C4	C/C++	Commercial (\$3,000/yr)	EDR evasion focused, syscall-based, newer detection gaps	High
Sliver	Go	Open Source (BSD)	Free, cross-platform, multiplayer, active development by BishopFox	Moderate
Mythic	Python/Go	Open Source (BSD)	Modular agent system, great for custom payloads, excellent UI	Moderate
Havoc	C/C++	Open Source	Modern design, demon agent, good for learning C2 internals	Moderate
Nighthawk	C	Commercial (expensive)	Premium evasion, used by top-tier consulting firms	Very High

C2 Infrastructure Architecture



Infrastructure Best Practices

- **Domain aging:** Register domains 30+ days before use and categorize them with web content to avoid reputation-based blocks
- **Redirector chains:** Never expose your team server directly. Use at least two layers of redirectors between the implant and your C2
- **Certificate management:** Use legitimate TLS certificates from Let's Encrypt. Self-signed certs are an instant red flag for network monitoring
- **Traffic profiling:** Configure your C2 traffic to mimic legitimate services (Microsoft 365, Slack, Google APIs). Use malleable C2 profiles.
- **Automation:** Use Terraform or Ansible to deploy and tear down infrastructure. You should be able to rebuild everything in under 30 minutes
- **Separation:** Use different C2 channels for different operation phases. Your initial access channel should not be the same as your post-exploitation channel

Build your C2 lab

Get infrastructure templates at [career.hadess.io](#)

Get Started →

MITRE ATT&CK is the common language between red teams and blue teams. Every red team report should map findings to ATT&CK techniques, and every operation plan should reference the techniques you intend to exercise. If you are not fluent in ATT&CK, you are leaving impact on the table.

Most Used ATT&CK Tactics in Red Team Operations

TACTIC	KEY TECHNIQUES	RED TEAM USAGE
Initial Access (TA0001)	Phishing (T1566), Valid Accounts (T1078), External Remote Services (T1133)	Every engagement starts here. Phishing remains the most reliable entry point.
Execution (TA0002)	PowerShell (T1059.001), Windows Management Instrumentation (T1047), Scheduled Task (T1053)	Running implants and payloads on target systems after initial access.
Persistence (TA0003)	Registry Run Keys (T1547.001), Scheduled Tasks (T1053.005), DLL Side-Loading (T1574.002)	Maintaining access across reboots and user logoffs during multi-week ops.
Privilege Escalation (TA0004)	Token Manipulation (T1134), Exploitation for Priv Esc (T1068), ADCS Abuse (T1649)	Moving from standard user to local admin to domain admin.
Defense Evasion (TA0005)	Process Injection (T1055), AMSI Bypass, Masquerading (T1036), Timestomping (T1070.006)	The tactic that defines red teaming. Every action must consider evasion.
Credential Access (TA0006)	Kerberoasting (T1558.003), DCSync (T1003.006), LSASS Dumping (T1003.001)	Collecting credentials to move laterally without triggering alarms.
Lateral Movement (TA0008)	Remote Services (T1021), Pass the Hash (T1550.002), SSH (T1021.004)	Spreading through the network to reach target systems and data.
Collection (TA0009)	Data from Shared Drives (T1039), Email Collection (T1114), Screen Capture (T1113)	Gathering evidence of crown jewel access for the final report.

Using ATT&CK in Your Operations

- **Planning:** Map your operation plan to specific techniques before you start. This forces you to think about what detections the SOC might have.
- **Execution:** Log every technique you use with timestamps. This makes report writing dramatically faster.
- **Reporting:** Include an ATT&CK navigator layer in your report showing which techniques were tested and which were detected.
- **Purple teaming:** Use ATT&CK as the shared vocabulary with detection engineers. Instead of "we used Mimikatz," say "we exercised T1003.001 (LSASS Memory) using a direct syscall approach that bypassed Credential Guard."

Threat Actor Emulation

The real power of ATT&CK for red teamers is threat actor profiles. When a client says "we are worried about APT29," you can pull up the ATT&CK profile for APT29, see every technique they use, and build an operation plan that mirrors their actual tradecraft. This makes your engagement directly relevant to the threats the organization faces, instead of running generic attacks.

Evasion and Defense Bypass

Evasion is what separates a red teamer from a penetration tester. Anyone can run Mimikatz on an unprotected host. The challenge is getting it to work on a machine running CrowdStrike Falcon, Microsoft Defender for Endpoint, or SentinelOne without triggering an alert. This is the most technically demanding skill in the red team toolkit.

Defense Layers You Need to Bypass

DEFENSE	WHAT IT DOES	BYPASS APPROACH
AMSI	Scans PowerShell, VBScript, JScript, and .NET assemblies at runtime	Patching amsi.dll in memory, string obfuscation, reflection-based loading
ETW	Provides telemetry that EDR agents consume for behavioral detection	Patching ntdll!EtwEventWrite, unhooking ETW providers
User-mode hooks	EDR agents hook ntdll functions to monitor API calls	Direct syscalls, indirect syscalls, fresh ntdll copy from disk or KnownDlls
Kernel callbacks	Process/thread/image load notifications to the EDR driver	Callback removal (requires admin), process hollowing, module stomping
Credential Guard	Virtualizes LSASS to prevent credential dumping	DPAPI abuse, Kerberos ticket extraction, shadow credentials, ADCS abuse
AppLocker / WDAC	Application whitelisting to prevent unauthorized executables	LOLBAS, DLL side-loading, script host abuse, trusted folder bypasses
Email Security Gateway	Blocks phishing payloads and malicious attachments	HTML smuggling, QR code phishing, OneNote containers, encrypted archives

Process Injection Techniques

Classic Techniques

- CreateRemoteThread injection
- NtQueueApcThread (early bird)
- Process hollowing (RunPE)
- Thread hijacking
- DLL injection via LoadLibrary

Modern Evasive Techniques

- Module stomping (overwriting loaded DLLs)
- Phantom DLL hollowing
- Thread pool injection (TP_WORK)
- Fiber-based execution
- Callback-based injection (TLS, vectored exception handlers)

The Arms Race Reality

EDR vendors update their detection logic weekly. A bypass that works today might get flagged next Tuesday. This means evasion is not something you learn once. It is a continuous research discipline. The best red teamers spend several hours each week testing their techniques against updated EDR agents in lab environments. They read vendor blog posts, monitor detection rule updates, and adapt their tooling accordingly. If your evasion approach is more than 3 months old and you have not tested it recently, assume it is burned.

Stay ahead of defenses

Track the latest evasion research at career.hadess.io

Research →

Initial Access Tradecraft

You cannot hack what you cannot reach. Initial access is the first and often hardest phase of a red team engagement. The target organization has invested heavily in perimeter defenses, email filtering, and endpoint protection. Your job is to find the one gap that gets you inside.

Initial Access Vectors

VECTOR	SUCCESS RATE	EFFORT	DETECTION RISK
Spear phishing with payload	High	Medium	Medium
Callback phishing (vishing)	High	Low	Low
Compromised credentials (OSINT)	Medium	Low	Low
Exposed services (VPN, RDP, Citrix)	Medium	Medium	Medium
Supply chain (trusted partner)	Medium	High	Low
Physical access (badge cloning, tailgating)	High	High	High
USB drop (rubber ducky, O.MG cable)	Low	Medium	Medium

Phishing Payload Evolution (2024 to 2026)

- **2024:** ISO files with embedded LNK shortcuts were the dominant payload format. Most email gateways blocked them by mid-year.
- **2025:** HTML smuggling gained popularity, delivering payloads through JavaScript that assembles files client-side, bypassing email scanning entirely.
- **2026:** QR code phishing (quishing) and adversary-in-the-middle (AiTM) phishing kits like Evilginx dominate. These bypass MFA by capturing session tokens in real-time.

OSINT for Initial Access

Before sending a single phishing email, spend time on reconnaissance. The intelligence you gather directly impacts your success rate.

- **Credential databases:** Check breach databases for employee credentials. Even old passwords reveal password patterns.
- **LinkedIn:** Map the org chart, identify new hires (they have not been trained on security policies yet), find employees who post about specific technologies
- **DNS and subdomain enumeration:** Find forgotten dev environments, staging servers, and shadow IT
- **GitHub and GitLab:** Search for hardcoded API keys, internal documentation, and infrastructure details in public repos
- **Job postings:** The technologies listed in job descriptions tell you exactly what the target runs internally

Perfect your initial access

Learn advanced phishing techniques at [career.hadess.io](#)

Learn →

Cloud Attack Paths

Cloud environments are now a mandatory skill for red teamers. Over 85% of enterprises use at least one major cloud provider, and the attack surface is fundamentally different from on-premises networks. The principles of red teaming still apply, but the tools, techniques, and thinking need to adapt.

Azure / Entra ID Attack Paths

TECHNIQUE	IMPACT	TOOLS
Token theft from az CLI / browser	Access Azure resources as the compromised user	ROADtools, TokenTactics, AADInternals
Managed Identity abuse	Pivot from a compromised VM to other Azure resources	IMDS endpoint, curl
Application consent phishing	Gain persistent access to user mailboxes and files	365-Stealer, custom OAuth apps
Conditional Access bypass	Access resources from untrusted devices or locations	Device code phishing, token replay
Cross-tenant access	Pivot between Azure tenants via B2B or partner relationships	AADInternals, manual API calls

AWS Attack Paths

TECHNIQUE	IMPACT	TOOLS
IAM role chaining	Escalate privileges by assuming roles across accounts	Pacu, enumerate-iam, aws CLI
SSRF to IMDS	Steal IAM credentials from EC2 instances via metadata service	Manual exploitation, IMDSv1 targets
Lambda function abuse	Execute code with the Lambda's IAM role permissions	Pacu, custom scripts
S3 bucket enumeration	Access sensitive data in misconfigured buckets	S3Scanner, aws CLI, bucket-finder
CloudTrail evasion	Operate without generating audit logs	Disabling logging, data event gaps, read-only APIs

Cloud Red Teaming Is Different

In cloud environments, identity is the new perimeter. There are no firewalls to bypass or network segments to cross. Instead, you exploit IAM misconfigurations, overly permissive roles, and token-based authentication flows. The mental model shifts from "how do I move through this network" to "how do I escalate my identity privileges to access the target resource."

Red teamers who invest in cloud skills now will have a significant advantage over the next 3 to 5 years. Most organizations are still figuring out cloud security, and the gap between attacker capability and defender maturity is wider in cloud than anywhere else.

Master cloud attacks

Cloud red team training paths at [career.hadess.io](#)

Explore →

Exploit Development Fundamentals

Not every red teamer needs to write exploits from scratch. But understanding exploit development makes you dramatically better at everything else. When you understand how buffer overflows, use-after-free vulnerabilities, and type confusion bugs work at a low level, you develop intuition about where vulnerabilities hide and how defenses can be circumvented.

Exploit Development Skill Tiers

TIER	SKILLS	WHO NEEDS THIS
Tier 1: Consumer	Use public exploits, modify proof-of-concept code, understand CVE descriptions and patch diffs	All red teamers. This is the minimum bar.
Tier 2: Adapter	Port exploits between platforms, write shellcode, build custom loaders, understand memory protections (DEP, ASLR, CFG)	Mid-level operators who want to customize payloads and bypass specific defenses.
Tier 3: Developer	Discover and exploit 0-day vulnerabilities, write kernel exploits, reverse engineer binaries, develop ROP/JOP chains	Specialized exploit developers and vulnerability researchers. Very few red teamers reach this level.

Key Concepts Every Red Teamer Should Know

- **Stack buffer overflow:** The classic bug. Understanding this is the foundation for everything else in exploit dev.
- **Heap exploitation:** Use-after-free, heap spraying, and heap grooming techniques used in modern browser and OS exploits
- **Return-Oriented Programming (ROP):** Chaining existing code gadgets to bypass DEP. Essential for understanding modern exploitation.
- **ASLR bypass:** Information leaks, partial overwrites, and other techniques to defeat address randomization
- **Shellcode writing:** Custom position-independent code that runs in the context of an exploited process
- **Windows kernel exploitation:** Driver vulnerabilities, token stealing, and privilege escalation from user mode to SYSTEM

Recommended Learning Path

OffSec EXP-301 (OSED)

Corelan Exploit Writing

HackSys Extreme Vulnerable Driver

pwn.college

ROP Emporium

Where Exploit Dev Fits in Red Teaming

During most engagements, you will use existing tools and public exploits. The value of exploit development knowledge shows up in edge cases: when you need to modify a public exploit for a slightly different target version, when you need to write custom shellcode to evade a specific EDR, or when the only path to your objective goes through a vulnerability that has no public exploit. Those moments are rare, but when they happen, the operator who can adapt is the one who completes the mission.

Build your exploit dev skills

Find structured learning paths at [career.hadess.io](#)

Learn →

Physical Security and Social Engineering

Full-scope red team engagements include physical security and social engineering because real adversaries use them. A locked door or a well-trained receptionist is just another control to bypass. Some of the most impactful red team findings come from walking into a building, plugging into a network jack, and having domain admin before the digital operators even launch their first phishing email.

Physical Access Techniques

TECHNIQUE	DIFFICULTY	TOOLS / EQUIPMENT
Tailgating	Low	Clipboard, hi-vis vest, confident attitude, courier uniform
Badge cloning	Medium	Proxmark3, iCopy-X, long-range HID readers (Tastic RFID Thief)
Lock picking	Medium	Pick sets, tension wrenches, electric pick guns, bypass tools
Under-door tools	Low	Under-door camera, latch slipping tools
Network implant drops	Medium	LAN Turtle, Raspberry Pi with LTE, Shark Jack, WiFi Pineapple
USB drops	Low	Rubber Ducky, O.MG Cable, BadUSB devices

Social Engineering Approaches

Remote Social Engineering

- **Vishing:** Calling employees while impersonating IT support, vendors, or executives
- **Smishing:** SMS-based phishing with urgent pretexts about password resets or delivery notifications
- **Callback phishing:** Emails that ask the target to call a number, where an operator handles the call
- **Pretext development:** Building believable cover stories using OSINT about the target organization

In-Person Social Engineering

- **Impersonation:** IT technician, fire inspector, elevator repair, vendor representative
- **Authority exploitation:** Dropping names of executives, referencing internal projects found via OSINT
- **Urgency creation:** Manufacturing time pressure to prevent targets from verifying your identity
- **Reverse social engineering:** Creating a problem then offering to fix it to gain access

Legal and Ethical Boundaries

Physical and social engineering tests require explicit written authorization, clear scope definitions, and emergency contacts. Always carry your authorization letter. Know the boundaries: you may be authorized to tailgate into the building but not to open locked drawers. Recording conversations may be illegal in two-party consent states. The best physical operators are the ones who know exactly where the line is and never cross it. One misstep can end your career and create serious legal liability for your employer.

Add physical to your skillset
Explore full-scope red team training at [career.hadess.io](#)

Explore →

Purple Teaming and Reporting

The value of a red team operation is not measured by how many shells you pop. It is measured by how much the organization's security posture improves as a result of your work. Purple teaming and effective reporting are what turn your technical findings into lasting security improvements.

Purple Team Execution Framework

PHASE	ACTIVITIES	PARTICIPANTS
1. Technique Selection	Choose 5 to 10 ATT&CK techniques to test based on threat intel and prior gaps	Red team lead, detection engineering lead, threat intel
2. Baseline Assessment	Document current detection coverage for selected techniques	Detection engineers, SOC analysts
3. Controlled Execution	Red team executes each technique with the blue team watching in real-time	Red team operators, SOC analysts, detection engineers
4. Detection Gap Analysis	Document which techniques were detected, which were missed, and why	Both teams together
5. Detection Development	Build or improve detections for the techniques that were missed	Detection engineers with red team input
6. Validation	Red team re-executes techniques to confirm new detections work	Red team operators

Report Structure That Gets Results

- **Executive summary (1 page):** Business impact, not technical details. "We accessed the M&A database containing \$2B in pending deals through a three-step attack chain starting with a phishing email to the legal department."
- **Attack narrative (3 to 5 pages):** Tell the story chronologically. What you did, when, how you avoided detection, and where defenders succeeded or failed.
- **ATT&CK coverage map:** Visual navigator layer showing tested techniques with color-coded detection status
- **Findings with remediation (bulk of report):** Each finding includes the technique, evidence, business impact, and specific remediation steps
- **Positive observations:** Call out what the defenders did right. This builds trust and encourages continued investment in detection capabilities.
- **Metrics dashboard:** Detection rate, mean time to detect, mean time to respond, techniques tested vs. detected

Common Reporting Mistakes

- Writing for other hackers instead of the audience who will act on the findings
- Listing vulnerabilities without connecting them to business impact
- Not including positive observations (defenders need to know what is working)
- Overly technical language in the executive summary
- No clear remediation priorities (everything is "critical")

Improve your reporting

Get red team report templates at career.hadess.io

Get Templates →

Certifications matter in offensive security, but not all certifications matter equally. The ones that carry weight with hiring managers are the ones that require you to demonstrate practical skills, not just pass a multiple-choice exam. Here is how to invest your certification budget for maximum career impact.

Certification Priority Matrix

CERTIFICATION	PROVIDER	COST	DIFFICULTY	CAREER IMPACT	BEST FOR
OSCP	OffSec	\$1,749+	Hard	Very High	Getting your first offensive security job
CRT0	Zero-Point Security	\$499	Hard	High	Proving red team specific skills (Cobalt Strike, AD)
CRTP	Altered Security	\$299	Medium	High	Active Directory attack specialization
OSEP	OffSec	\$1,749+	Very Hard	Very High	Evasion, lateral movement, advanced post-exploitation
OSED	OffSec	\$1,749+	Very Hard	High	Exploit development specialization
GXPN	GIAC/SANS	\$8,525+	Very Hard	High	Enterprise environments, government/DoD positions
OSCE3	OffSec	\$5,247+ total	Expert	Very High	The triple crown: OSEP + OSWE + OSED combined
CREST CRT	CREST	Varies	Hard	High (UK/EU)	Required for CBEST and TIBER-EU engagements

Recommended Order



Plan your certification path

Get personalized cert recommendations at career.hadess.io

Plan →

OSCP, OSEP, and OSED Deep Dive

The OffSec certification trilogy is the most recognized credential path in offensive security. Each certification builds on the previous one and tests progressively harder skills in a practical, hands-on exam environment.

OSCP (Offensive Security Certified Professional)

ASPECT	DETAILS
Course	PEN-200: Penetration Testing with Kali Linux
Exam Format	24-hour practical exam: compromise multiple machines in a simulated network, plus an Active Directory set
Key Skills Tested	Enumeration, exploitation, privilege escalation, basic Active Directory attacks, report writing
Preparation Time	3 to 6 months for most candidates
Pass Rate	Approximately 20% to 25% on first attempt
Career Impact	The single most important cert for getting your first offensive security job. Required or preferred by 70%+ of job postings.

OSEP (Offensive Security Experienced Penetration Tester)

ASPECT	DETAILS
Course	PEN-300: Evasion Techniques and Breaching Defenses
Exam Format	48-hour practical exam: breach a hardened enterprise environment with AV, AppLocker, and network segmentation
Key Skills Tested	AV/EDR evasion, process injection, lateral movement in hardened AD, custom payload development
Preparation Time	4 to 8 months after OSCP
Career Impact	Strong differentiator for mid-level to senior red team roles. Proves you can operate in defended environments.

OSED (Offensive Security Exploit Developer)

ASPECT	DETAILS
Course	EXP-301: Windows User Mode Exploit Development
Exam Format	48-hour practical exam: develop working exploits for Windows applications with modern mitigations
Key Skills Tested	Stack overflows, SEH exploitation, ROP chain building, format strings, egghunters, shellcode development
Preparation Time	4 to 8 months with prior low-level programming experience
Career Impact	Specialized value. Best for those pursuing exploit development or vulnerability research roles.

OSCE3: The Triple Crown

OSCE3 is awarded when you hold OSEP, OSWE (web), and OSED simultaneously. Fewer than 2,000 people worldwide hold this credential. It signals elite-level offensive capability and commands a significant salary premium, typically \$20K to \$40K above comparable candidates without it. If you are planning to pursue OSCE3, budget 18 to 24 months and roughly \$5,000 to \$6,000 in course and exam fees.

Earn your OSCP

Get study strategies and prep resources at career.hadess.io

Prepare →

CRTO, CRTP, and GXPN

While OffSec certifications dominate job postings, these three certifications fill critical gaps that OffSec does not cover. CRTO teaches real C2 operations, CRTP goes deep on Active Directory, and GXPN covers advanced exploitation techniques with the weight of a SANS/GIAC credential behind it.

CRTO (Certified Red Team Operator)

ASPECT	DETAILS
Provider	Zero-Point Security (Daniel Duggan / RastaMouse)
Cost	\$499 for course + exam
Exam Format	48-hour practical: full red team engagement in a simulated enterprise using Cobalt Strike
Key Skills	Cobalt Strike, Malleable C2 profiles, AD exploitation, lateral movement, evasion, full operation lifecycle
Why It Matters	The only mainstream certification that teaches commercial C2 operations. Extremely well-regarded by hiring managers who run red teams.

CRTP (Certified Red Team Professional)

ASPECT	DETAILS
Provider	Altered Security (Nikhil Mittal)
Cost	\$299 for course + exam
Exam Format	24-hour practical: compromise a multi-forest Active Directory environment
Key Skills	Kerberos attacks, delegation abuse, trust exploitation, forest hopping, ADCS abuse, PowerShell-based attacks
Why It Matters	The best value certification for Active Directory skills. At \$299, it has the highest ROI of any offensive security cert.

GXPN (GIAC Exploit Researcher and Advanced Penetration Tester)

ASPECT	DETAILS
Provider	GIAC / SANS (SEC660)
Cost	\$8,525+ (course + exam) or \$2,499 (exam only if self-study)
Exam Format	Proctored written exam with applied scenarios (75 questions, 3 hours). Open book.
Key Skills	Network attacks, crypto attacks, exploitation, shellcode, ROP, heap exploitation
Why It Matters	GIAC certifications carry weight in government and defense sectors. Required or preferred for many DoD and intelligence community positions.

Which Should You Get First?

If you already have OSCP and want to move specifically into red teaming, get CRTO. It teaches the exact skills you will use on day one of a red team engagement, and at \$499 it is hard to beat on value. If you are targeting Active Directory heavy environments (which is most enterprises), CRTP is an excellent complement. GXPN makes sense if your employer pays for it or if you are targeting government/defense positions where GIAC credentials are valued.

Choose the right certification

Get personalized guidance at career.hadess.io

Get Guidance →

A home lab is not optional for red teamers. It is where you practice techniques without the pressure of a live engagement, test evasion against real EDR products, and build the muscle memory that makes you effective on operations. Here is how to build one that mirrors real enterprise environments.

Minimum Hardware Requirements

COMPONENT	MINIMUM	RECOMMENDED	WHY
RAM	32 GB	64 GB	Running 2 DCs, 3 to 5 workstations, and an attack VM simultaneously
CPU	8 cores	16 cores	Multiple VMs need dedicated cores for smooth operation
Storage	500 GB SSD	1 TB NVMe	Windows VMs are 30 to 50 GB each; snapshots add up fast
GPU	GTX 1070+	RTX 3060+	Password cracking with hashcat. More VRAM = faster cracking.

Lab Architecture

- **Domain Controller 1:** Windows Server 2022, primary DC, ADCS installed with vulnerable templates (ESC1, ESC4)
- **Domain Controller 2:** Windows Server 2019, secondary DC, different OU structure for trust testing
- **Workstation 1:** Windows 11, joined to domain, CrowdStrike Falcon or Defender for Endpoint installed
- **Workstation 2:** Windows 10, joined to domain, standard user account, simulated email client
- **Workstation 3:** Windows 10, different subnet, SQL Server installed with service account running as domain user
- **Linux Server:** Ubuntu 22.04, simulated web server, SSH enabled, some misconfigurations
- **Attack VM:** Kali Linux or custom attack distro with your tooling
- **C2 Server:** Separate VM running Sliver, Cobalt Strike, or Mythic

Automation with Ludus, DVAD, or GOAD

Manually setting up an AD lab takes hours. Use automation frameworks to deploy vulnerable labs in minutes:

Ludus (Terraform-based)

GOAD (Game of Active Directory)

DetectionLab

DVAD (Damn Vulnerable AD)

BadBlood (AD population)

What to Practice

Start with the basics: run SharpHound, analyze the BloodHound graph, find a path to domain admin. Then practice the same attack chain with different evasion techniques. Try it with AMSI enabled, then with Defender real-time protection on, then with a trial EDR agent installed. The goal is not just to succeed, but to understand exactly which of your actions trigger which detections, so you know what to avoid on a real engagement.

Build your lab today

Get step-by-step lab setup guides at career.hadess.io

Build →

Essential Tools by Category

C2 Frameworks

- Cobalt Strike
- Brute Ratel C4
- Sliver
- Mythic
- Havoc
- Nighthawk

Active Directory

- BloodHound / SharpHound
- Rubeus
- Mimikatz
- Impacket
- CrackMapExec / NetExec
- Certify / Certipy
- Whisker
- StandIn
- ADCSPwn
- PowerView

Reconnaissance

- Nmap
- Subfinder
- Amass
- httpx
- Nuclei
- theHarvester
- Shodan
- Censys

Credential Attacks

- Hashcat
- John the Ripper
- Hydra
- Spray (password spraying)
- DomainPasswordSpray
- KeeThief
- LaZagne

Evasion and Payload Development

- ScareCrow
- Nimcrypt2
- Donut
- Freeze
- SharpUnhooker
- SysWhispers
- InlineWhispers

Cloud Tools

- ROADtools
- AADInternals
- Pacu
- ScoutSuite
- Prowler
- TokenTactics
- GraphRunner

Physical Security

- Proxmark3
- WiFi Pineapple
- Flipper Zero
- LAN Turtle
- Rubber Ducky
- O.MG Cable
- HackRF One

Web Application

- Burp Suite Pro
- SQLMap
- ffuf
- Gobuster
- Evilginx
- Gophish

Infrastructure and Automation

- Terraform
- Ansible
- Nebula (mesh VPN)
- Nginx (redirectors)
- Caddy
- Cloudflare Workers

Choosing Your Toolkit

You do not need every tool on this list. Start with the essentials: one C2 framework (Sliver is free and excellent for learning), BloodHound for AD, Impacket for remote exploitation, and Burp Suite for web. Add specialized tools as your engagements require them. The best operators know 5 to 10 tools deeply rather than 50 tools superficially.

Build your toolkit

Get tool recommendations based on your focus area at [career.hadess.io](#)

Explore →

Essential Books

Red Team Development and Operations

Joe Vest & James Tubberville

The Hacker Playbook 3

Peter Kim

Attacking Network Protocols

James Forshaw

Windows Internals Part 1

Russinovich, Solomon & Ionescu

Evading EDR

Matt Hand

Operator Handbook

Netmux

More Recommended Reading

BOOK	AUTHOR	FOCUS
Red Team: How to Succeed by Thinking Like the Enemy	Micah Zenko	Red team philosophy and organizational psychology
Social Engineering: The Science of Human Hacking	Christopher Hadnagy	Human manipulation techniques and defense
Practical Malware Analysis	Sikorski & Honig	Understanding malware behavior for tool development
The Art of Network Penetration Testing	Royce Davis	Practical network pentesting methodology

Podcasts

PODCAST	WHY LISTEN
Darknet Diaries	True stories from the dark side of the internet. Great for understanding real-world attack scenarios and the people behind them.
Risky Business	Weekly security news with industry insider perspective. Essential for staying current on the threat landscape.
The Red Team Podcast	Interviews with red team practitioners discussing tradecraft, career development, and operational stories.
Malicious Life	History of cybersecurity events and hacking incidents. Good context for understanding how the field evolved.
Security Weekly (Hack Naked News)	Technical deep dives into vulnerabilities, tools, and exploitation techniques.

Online Learning Platforms

HackTheBox Pro Labs

TryHackMe

PortSwigger Academy

Altered Security Labs

Zero-Point Security

pwn.college

Cybrary

SANS OnDemand

Blogs You Should Follow

- SpecterOps:** Cutting-edge AD research, BloodHound development, and red team methodology
- MDSec:** Advanced evasion techniques, C2 development, and red team operations
- Outflank:** EDR evasion research, OS internals, and offensive tooling
- Red Team Notes (ired.team):** Practical technique reference and cheat sheets
- HackTricks:** Comprehensive offensive security knowledge base

Never stop learning

Get curated learning resources at [career.hadess.io](#)

Learn →

Conferences and Community

The offensive security community is small, and reputation matters enormously. The people you meet at conferences and in online communities become your future colleagues, mentors, and hiring managers. Building genuine relationships in this space is one of the highest-ROI investments you can make for your career.

Must-Attend Conferences

CONFERENCE	LOCATION	COST	WHY ATTEND
DEF CON	Las Vegas, Aug	\$460	Largest hacker conference. Red Team Village, AD Hacking Village, networking with the community.
Black Hat USA	Las Vegas, Aug	\$2,695+	Corporate-focused. Employer-sponsored. Great for arsenal tools and vendor research.
BlueHat	Redmond, Oct	Invite only	Microsoft's internal security conference. Invitation is a career milestone for offensive researchers.
SO-CON	Arlington, Mar	\$500	SpecterOps conference. The best AD and identity-focused offensive content anywhere.
Wild West Hackin' Fest	Deadwood, Oct	\$399	Smaller, community-driven. Great training workshops and approachable speakers.
Objective by the Sea	Various, varies	\$499	macOS and Apple security focus. Growing niche for red teamers targeting Apple environments.
x33fcon	Gdansk, Jun	\$300	European offensive security conference with excellent technical content and small community feel.

Online Communities

COMMUNITY	PLATFORM	VALUE
BloodHound Slack	Slack	Active Directory research, BloodHound development, direct access to SpecterOps researchers
Cobalt Strike Discord	Discord	C2 operations, BOF development, Malleable C2 profile sharing
InfoSec Twitter/X	Twitter/X	Real-time technique sharing, tool releases, job postings, and industry news
r/redteamsec	Reddit	Technique discussion, career questions, tool reviews
HackTheBox Discord	Discord	CTF discussion, machine walkthroughs, study groups for OSCP and other certs

Building Your Reputation

- **Write blog posts:** Document techniques you learn, tools you build, and challenges you solve. Even simple writeups build credibility.
- **Release open-source tools:** Even small utilities show you can code and contribute to the community.
- **Speak at local meetups:** BSides conferences are accessible and a great place to practice presenting before larger venues.
- **Help others:** Answer questions in Discord servers and forums. The community remembers who was helpful when they were learning.

Join the community

Connect with offensive security professionals at [career.hadess.io](#)

Connect →

Finance and Banking Red Teams

Financial services run some of the most mature red team programs in the world. Regulatory frameworks like TIBER-EU, CBEST, and DORA mandate threat-led penetration testing, which means banks need skilled red teamers year-round. The pay is excellent, but the bar for entry is high and the compliance requirements are strict.

Why Finance Pays Top Dollar

\$260K+

Average total compensation for senior red teamers at major banks (JPMorgan, Goldman Sachs, Citi)

TIBER-EU

European framework requiring threat-intelligence-led red team tests for systemically important financial institutions

24/7 SOC

Financial SOCs are staffed around the clock, making stealth much harder and your skills more valuable

Regulatory Frameworks

FRAMEWORK	REGION	REQUIREMENTS	CERTIFICATION NEEDED
TIBER-EU	European Union	Threat intelligence-led red team testing against critical functions of financial entities	CREST CRT or equivalent
CBEST	United Kingdom	Bank of England mandated testing for UK financial institutions	CREST registered, CHECK team leader
DORA	European Union	Digital Operational Resilience Act requiring TLPT (Threat-Led Penetration Testing)	TIBER-EU aligned
FFIEC CAT	United States	Cybersecurity assessment tool with red team testing expectations for mature programs	No specific cert required

What Makes Finance Different

- Scope restrictions:** You often cannot test production trading systems during market hours. Operations are carefully scheduled around business cycles.
- Legal complexity:** Cross-border operations require coordination with multiple regulators. Testing a London bank's New York branch involves UK and US legal frameworks.
- Mature defenses:** Banks invest heavily in security. You will face well-staffed SOCs, advanced EDR, network segmentation, and DLP. Easy wins are rare.
- Swift and payment systems:** Understanding SWIFT, FedWire, and payment rail security is specialized knowledge that commands premium rates.
- Background checks:** Expect thorough vetting including criminal records, credit checks, and sometimes government security clearance.

Top Employers in Finance

Goldman Sachs

JPMorgan Chase

Citi

Bank of America

Morgan Stanley

HSBC

Barclays

Deutsche Bank

Two Sigma

Citadel

Break into finance red teaming

Get industry-specific guidance at [career.hadess.io](#)

Explore →

Government, Military, and Intelligence

Government and military red teams operate at a level of sophistication that most private sector teams never reach. The targets are classified systems, the adversaries are nation-states, and the stakes include national security. The trade-off is lower base salary compared to big tech, but unmatched training, access to classified tools and techniques, and a level of operational experience that private sector roles simply cannot provide.

Key Government Red Team Programs

ORGANIZATION	PROGRAM	FOCUS
NSA	Red Team (TAO/CES)	Offensive operations against classified networks and foreign targets
US Cyber Command	Cyber National Mission Force	Defensive and offensive cyber operations in support of military objectives
DISA	Red Team Division	Testing DoD networks and systems for vulnerabilities
GCHQ / NCSC	Various programs	UK government offensive and defensive cyber operations
CISA	Red Team Assessments	Testing critical infrastructure and federal civilian agencies

Clearance Requirements

- **Secret:** Minimum for most DoD contractor red team positions. Takes 3 to 6 months to process.
- **Top Secret / SCI:** Required for intelligence community positions. Full background investigation takes 6 to 18 months.
- **Polygraph:** Some positions require CI or full-scope polygraph. This adds months to the clearance timeline.
- **Lifestyle factors:** Drug use, foreign contacts, financial problems, and criminal history can disqualify candidates. Plan years ahead.

Compensation

ROLE	GOVERNMENT (GS SCALE)	CONTRACTOR
Junior Red Teamer	\$75K – \$100K (GS-12)	\$110K – \$140K
Mid-Level Operator	\$100K – \$130K (GS-13/14)	\$140K – \$180K
Senior / Team Lead	\$130K – \$175K (GS-15/SES)	\$180K – \$240K

Why People Choose Government

The pay gap compared to big tech is real, typically 30% to 50% less in total compensation. But government red teamers get access to tools, techniques, and training that the private sector cannot match. You work against the hardest targets in the world, you receive world-class training from organizations like SANS and NSA internal courses, and the security clearance you build opens doors for the rest of your career. Many of the best red team consultants in private practice started in government and leveraged that experience into premium billing rates.

Explore government paths

Learn about clearance requirements at career.hadess.io

Learn More →

Consulting is where many red teamers build their careers. You work across multiple clients, industries, and technology stacks, which accelerates your learning faster than any internal role. The trade-off is travel, utilization pressure, and the constant need to scope, sell, and deliver engagements on tight timelines.

Types of Consulting Firms

TYPE	EXAMPLES	PROS	CONS
Big Four	Deloitte, PwC, EY, KPMG	Large client base, global mobility, structured career path, brand recognition	Bureaucracy, utilization targets, less technical depth, lots of compliance work
Specialized Security	CrowdStrike Services, Mandiant, Secureworks, NCC Group, WithSecure	Technical depth, strong reputation, access to threat intel, research time	Travel heavy, high utilization (75%+), competitive but not top-tier pay
Boutique Offensive	SpecterOps, TrustedSec, NetSPI, Praetorian, Coalfire	Best technical work, cutting-edge tradecraft, strong community reputation, collaborative culture	Smaller firms mean fewer promotion tracks, variable benefits, feast-or-famine revenue cycles
Independent	Solo practitioners	Complete autonomy, highest earning potential (\$300+/hr), choose your clients	You handle sales, accounting, legal, and insurance. No benefits. No team to learn from.

Consulting Compensation

LEVEL	BIG FOUR	SPECIALIZED	BOUTIQUE
Junior Consultant	\$85K – \$110K	\$100K – \$130K	\$110K – \$140K
Senior Consultant	\$120K – \$160K	\$140K – \$180K	\$150K – \$200K
Manager / Lead	\$160K – \$210K	\$180K – \$230K	\$190K – \$250K
Director / Partner	\$210K – \$350K+	\$220K – \$300K	\$250K – \$400K+

Day Rates for Independent Consultants

Independent red team consultants in the US market charge between \$2,000 and \$4,000 per day depending on specialization and reputation. Top-tier operators with strong publications, conference talks, and proven track records can command \$4,000 to \$6,000 per day for specialized work like TIBER-EU assessments or assumed breach exercises against hardened environments. At 200 billable days per year, that translates to \$400K to \$800K+ in revenue before expenses.

Resume Building for Red Teamers

Red team hiring managers see hundreds of resumes. Most look the same: a list of tools and certifications with vague bullet points about "conducting penetration tests." The resumes that get interviews are the ones that show measurable impact, specific techniques, and real operational outcomes.

Resume Structure That Works

SECTION	WHAT TO INCLUDE	WHAT TO AVOID
Summary	2 to 3 sentences: years of experience, specialization, key achievement	Generic statements like "passionate security professional"
Experience	Impact-driven bullets with metrics: "Achieved domain admin in 18/20 engagements via AD attack paths"	Task lists: "Performed penetration testing activities"
Skills	Grouped by category: C2 Frameworks, AD Tools, Cloud, Languages	Long undifferentiated lists of every tool you have heard of
Certifications	OSCP, OSEP, CRT0, CRTP with dates	CompTIA A+ from 2015 (remove outdated, irrelevant certs)
Projects	Open-source tools, blog posts, conference talks, CTF placements	School projects or generic portfolio websites

Strong Bullet Point Examples

- "Led 15 red team engagements across financial services, achieving primary objectives in 12 (80% success rate) against environments running CrowdStrike and Defender ATP"
- "Developed custom C2 implant in C# with syscall-based evasion that remained undetected across 8 consecutive engagements over 6 months"
- "Identified ADCS ESC1 misconfiguration affecting 3 production forests, enabling domain admin access from any authenticated user in under 5 minutes"
- "Built automated C2 infrastructure deployment pipeline using Terraform reducing setup time from 4 hours to 15 minutes per engagement"
- "Presented 'Shadow Credentials in the Wild' at BSides Las Vegas 2025 to an audience of 200+ practitioners"

Handling Confidential Work

Most red team work is confidential. You cannot name clients or share specific findings. Use patterns like: "Led adversary simulation for a Fortune 100 financial services company" or "Conducted TIBER-EU assessment for a major European bank." Focus on the techniques and outcomes rather than the specific target. Hiring managers who run red teams understand this constraint and will not penalize you for maintaining client confidentiality.

Optimize your resume

Get red team resume templates at [career.hadess.io](#)

Get Templates →

LinkedIn and Online Presence

Your online presence is your 24/7 recruiter. Hiring managers, recruiters, and peers will Google your name before they ever read your resume. A strong online presence multiplies your career opportunities without you having to apply for anything.

LinkedIn Profile Optimization

ELEMENT	STRONG EXAMPLE	WEAK EXAMPLE
Headline	Red Team Lead OSEP, C2 Adversary Simulation, AD Security, C2 Operations	Cybersecurity Professional Passionate about hacking
About	Specific: "I lead red team operations at [Company], specializing in Active Directory attack paths and EDR evasion. Previously built the offensive security practice at [Firm]."	Generic: "Experienced security professional with a passion for protecting organizations."
Experience	Impact bullets matching your resume with slightly more detail	Copy-pasting job descriptions
Skills	Top 3: Red Teaming, Active Directory Security, Adversary Simulation	50 skills including "Microsoft Word" and "Team Player"

Building a Technical Blog

- **Platform:** GitHub Pages with Hugo or Jekyll is free and gives you full control. Medium works but you do not own your content.
- **Content ideas:** CTF writeups, tool comparisons, technique deep dives, certification study guides, lab build tutorials
- **Frequency:** One quality post per month is enough. Consistency matters more than volume.
- **Promotion:** Share each post on Twitter/X with relevant hashtags. Tag the tool or technique creators when appropriate.

Twitter/X for Red Teamers

InfoSec Twitter is where techniques get shared first, tools get announced, and careers get made. Follow active researchers and practitioners. Share your own work. Engage in technical discussions. But be careful about what you share. Never post about active engagements, never share client information, and think carefully before posting novel techniques that could be used maliciously. The line between "helpful community member" and "liability" is thinner than you think.

GitHub Presence

- Open-source at least 2 to 3 tools or scripts that demonstrate your technical ability
- Even small utilities (a BloodHound custom query pack, a Sliver extension, a phishing template generator) show you can code
- Write clear README files with documentation. This shows communication skills as much as coding ability.
- Contribute to existing projects: pull requests to BloodHound, Impacket, or Sliver carry more weight than solo projects

Build your brand

Get personal branding strategies at career.hadess.io

Start →

Interview Prep: Technical

Red team interviews are among the most technical in cybersecurity. You will face scenario-based questions, live hacking challenges, and deep dives into your methodology. The best preparation is genuine experience, but knowing what to expect and how to structure your answers makes a real difference.

Common Technical Interview Questions

CATEGORY	SAMPLE QUESTION	WHAT THEY ARE TESTING
AD Attacks	"Walk me through how you would go from a standard domain user to domain admin in a hardened environment."	Depth of AD knowledge, methodology, ability to think through multiple paths
Evasion	"Our target runs CrowdStrike Falcon. How do you plan your payload delivery and execution?"	Understanding of EDR internals, practical evasion experience
C2	"Describe how you would set up C2 infrastructure for a 4-week engagement against a mature SOC."	Infrastructure planning, OPSEC awareness, practical C2 experience
Phishing	"The target uses Proofpoint for email security and Defender for endpoints. Walk me through your initial access plan."	Creativity, understanding of email security controls, payload development
Cloud	"You find an Azure managed identity on a compromised VM. What do you do next?"	Cloud attack path knowledge, practical Azure/AWS experience
Troubleshooting	"Your beacon stopped calling back after 6 hours. Walk me through your troubleshooting process."	Operational experience, calm under pressure, systematic thinking

Hands-On Lab Interviews

Many top red teams include a practical component. This typically takes one of two forms:

- **Take-home lab (24 to 72 hours):** You receive VPN access to a small AD environment and need to achieve a specific objective. Document your methodology. This tests your real-world skills under realistic conditions.
- **Live hacking session (2 to 4 hours):** You share your screen while working through a lab environment with the interviewer watching. This tests how you think, how you handle dead ends, and how you communicate while working.

How to Answer Technical Questions

- **Use the STAR method adapted for red team:** Situation (engagement context), Technique (what you used), Action (exactly what you did), Result (impact and outcome)
- **Show multiple paths:** "My first approach would be X, but if that fails because of Y, I would try Z." This shows depth beyond a single technique.
- **Acknowledge what you do not know:** "I have not done that specific attack in production, but here is how I would approach it based on my understanding." Honesty builds trust.
- **Reference real engagements:** "On a recent engagement, I faced a similar situation where..." Concrete experience beats theoretical knowledge every time.

Ace your interview

Practice with red team interview scenarios at career.hadess.io

Practice →

Interview Prep: Behavioral

Technical skills get you the interview. Behavioral questions determine whether you get the offer. Red team work requires judgment, communication, and the ability to work under pressure without cutting corners on ethics or safety. Interviewers use behavioral questions to assess these qualities.

Common Behavioral Questions

QUESTION	WHAT THEY WANT TO HEAR
"Tell me about a time an engagement went wrong. What happened and how did you handle it?"	Honesty, accountability, problem-solving. They want to see that you can recover gracefully, not that you have never made a mistake.
"How do you handle a situation where a client's SOC detects you mid-operation?"	Communication skills, flexibility, ability to adapt the plan without panicking or burning other implants.
"Describe a finding that was technically impressive but hard to explain to non-technical leadership."	Translation ability. Can you connect technical attack chains to business risk in a way that drives action?
"How do you decide when to stop pushing during an engagement?"	Judgment and ethics. They want operators who know the boundaries and will not cause real harm to production systems.
"Tell me about a time you disagreed with your team lead about the approach for an operation."	Professionalism, ability to voice concerns constructively, willingness to support the decision once it is made.
"How do you stay current with evolving TTPs and new techniques?"	Self-directed learning, community involvement, genuine curiosity about the craft.

Red Flags Interviewers Watch For

- **Ego over impact:** Bragging about what you broke without explaining the business value of the finding
- **Cowboy mentality:** Describing situations where you acted without authorization or pushed beyond scope
- **Poor communication:** Inability to explain technical concepts simply. If you cannot explain it in an interview, you cannot explain it in a board briefing.
- **Blame shifting:** Attributing failures to others instead of owning your part and explaining what you learned
- **No learning examples:** If you cannot describe a recent technique you learned or a mistake you grew from, it signals stagnation

Questions You Should Ask the Interviewer

- "How does the red team's work feed into the organization's detection engineering process?"
- "What does a typical engagement cadence look like? How many concurrent operations does the team run?"
- "How much time do operators get for research, tool development, and training?"
- "What C2 frameworks and infrastructure does the team currently use?"
- "How does the team handle purple teaming and deconfliction with the SOC?"

Prepare to impress

Get behavioral interview coaching at career.hadess.io

Prepare →

Salary Negotiation Tactics

Red teamers routinely leave \$10K to \$50K on the table by not negotiating. Offensive security is a seller's market with more open roles than qualified candidates. That leverage belongs to you, but only if you use it.

Negotiation Framework

STEP	ACTION	SCRIPT
1. Know your number	Research market rates on Levels.fyi, Glassdoor, and by talking to peers	"Based on my research, the market range for this role is \$X to \$Y."
2. Let them go first	Avoid stating your salary expectations before receiving an offer	"I would like to understand the full scope of the role before discussing compensation."
3. Anchor high	Counter at the top of the range or 10% to 15% above their initial offer	"I was targeting \$X based on my experience with [specific skill] and the market data I have seen."
4. Use competing offers	If you have multiple offers, use them as leverage (honestly)	"I am evaluating another offer at \$X, but I prefer your team because [genuine reason]. Can we close the gap?"
5. Negotiate beyond base	Signing bonus, RSUs, training budget, conference attendance, remote flexibility	"Could we add a \$15K signing bonus and \$5K annual training budget for certifications and conferences?"

Leverage Points for Red Teamers

- **OSEP or OSCE3:** These certifications are rare enough to command \$15K to \$30K premium over OSCP-only candidates
- **Active security clearance:** A TS/SCI clearance adds \$20K to \$40K in the government contractor market
- **Published research:** Conference talks and tool releases demonstrate thought leadership that justifies senior-level compensation
- **Niche specialization:** Cloud red teaming, exploit development, or TIBER-EU experience commands premium rates due to limited supply
- **Proven track record:** Quantifiable results from previous engagements (objective success rates, detection gap improvements) justify higher offers

What Not to Do

- Never accept the first offer without a counter. Recruiters expect negotiation.
- Never lie about competing offers. The community is small and dishonesty will catch up with you.
- Never negotiate over email when you can do it by phone. Tone matters and emails get misread.
- Never give an ultimatum unless you are genuinely willing to walk away.
- Never focus only on base salary. Total compensation (equity, bonus, training, PTO) often matters more long-term.

Maximize your offer

Get salary benchmarks and negotiation coaching at [career.hadess.io](#)

Negotiate →

Real Job Postings Analyzed

These are real red team job postings from Q1 2026, analyzed for salary, required skills, and what they reveal about what employers actually want. Use these to benchmark your own skills and identify gaps.

1. Google - Red Team Security Engineer

Base: \$168K – \$252K | Location: Sunnyvale, CA (Hybrid) | Level: L5/L6

- Adversary simulation
- Cloud security (GCP)
- Custom tooling development
- Vulnerability research
- OSCP preferred
- Cross-team collaboration

Key insight: Google emphasizes building custom tools over using commercial frameworks. Strong programming skills in C, C++, or Go are weighted heavily. They want operators who can also do vulnerability research.

2. Microsoft MORSE - Senior Red Team Operator

Base: \$161K – \$240K | Location: Redmond, WA (Hybrid) | Level: 64/65

- Active Directory attacks
- Azure/Entra ID
- Cobalt Strike
- Custom C2 development
- OSEP or OSCE3
- Purple team facilitation

Key insight: Microsoft's MORSE team specifically calls out experience with Entra ID (Azure AD) and cloud-native attack paths. They want people who can operate across hybrid environments and work closely with product security teams.

3. CrowdStrike - Red Team Consultant

Base: \$130K – \$200K | Location: Remote US | Level: Mid to Senior

- Client-facing consulting
- Full-scope red teaming
- Multiple C2 frameworks
- Report writing
- OSCP required
- Client communication

Key insight: Consulting role means travel (30% to 50%) and client-facing skills matter as much as technical ability. They explicitly mention report writing quality as a hiring criterion.

4. Meta - Offensive Security Engineer

Base: \$177K – \$251K | Location: Menlo Park, CA (Hybrid) | Level: E5/E6

- Adversary simulation
- Exploit development
- Custom implant development
- Mobile security
- OSEP preferred
- Research publication

Key insight: Meta values research output. They want operators who contribute to the offensive security community through talks, blog posts, or open-source tools. Mobile security experience is a differentiator for their platform.

5. Goldman Sachs - VP, Red Team

Base: \$175K – \$250K | Location: New York, NY (Hybrid) | Level: VP (Senior)

- Financial sector red teaming
- TIBER-EU / CBEST
- AD and cloud attacks
- Threat actor emulation
- CREST CRT preferred
- Regulatory communication

Key insight: Financial services roles require understanding of regulatory frameworks. TIBER-EU and CBEST experience is a major differentiator. The VP title means they expect leadership and stakeholder management capabilities alongside technical skills.

Find your next role

Browse curated red team positions at career.hadess.io

Browse Jobs →

Global Salary and Compensation Map

Red team salaries vary dramatically by geography. A senior operator in San Francisco earns 3x to 4x what the same role pays in Eastern Europe, but cost-of-living adjustments and remote work policies are closing the gap. Here is how compensation breaks down globally.

Senior Red Teamer Salary by Region (2026)



Salary by Sector (US Market, Senior Level)

SECTOR	BASE SALARY	TOTAL COMP	NOTES
FAANG / Big Tech	\$220K – \$270K	\$350K – \$500K+	Equity heavy. RSU vesting over 4 years.
Financial Services	\$200K – \$260K	\$280K – \$400K	Cash bonus heavy. 20% to 50% bonus typical.
Defense / Intelligence	\$150K – \$210K	\$160K – \$240K	Clearance premium. Limited equity.
Consulting	\$170K – \$230K	\$200K – \$300K	Utilization bonuses. Variable by firm size.
Healthcare / Pharma	\$160K – \$210K	\$190K – \$260K	Growing sector. Regulatory requirements driving demand.
Startup	\$150K – \$200K	\$200K – \$350K+	Lower base, higher equity upside. Risk/reward trade-off.

Remote Work Impact

Remote red team roles are increasingly common but many employers apply geographic pay adjustments. A company might offer \$220K base for a San Francisco operator but only \$180K for the same role performed from Austin, Texas. Some firms like CrowdStrike and NetSPI pay the same regardless of location. When evaluating remote roles, always ask about their geographic pay policy before getting too far in the process.

Benchmark your salary

Get market-specific compensation data at [career.hadess.io](#)

Benchmark →

AI Impact on Red Teaming

AI is changing offensive security, but not in the way most headlines suggest. LLMs will not replace red teamers. The job requires creativity, judgment, and adaptability that current AI cannot replicate. What AI will do is make individual operators more productive and raise the bar for what counts as "good enough" tradecraft.

AI Threat to Red Team Tasks

TASK	AI AUTOMATION RISK	WHY
Reconnaissance / OSINT	Medium	AI excels at processing large datasets and correlating information, but contextual judgment about what matters still requires human expertise
Phishing pretext creation	Medium	LLMs can draft convincing emails, but targeting decisions, timing, and operational context require human judgment
Vulnerability scanning	High	Already heavily automated. AI improves accuracy but this was never the core red team skill.
Exploit development	Very Low	Requires deep understanding of memory, architecture, and mitigations. AI can assist but cannot drive.
C2 operations and evasion	Very Low	Real-time operational decisions, OPSEC judgment, and creative problem-solving resist automation
AD attack path analysis	Low	BloodHound already uses graph analysis. AI can help prioritize paths but execution requires human skill.
Report writing	Medium	AI can draft findings from structured data, but narrative quality, business context, and recommendations need human judgment
Client communication	Very Low	Trust, credibility, and real-time adaptation to stakeholder reactions cannot be automated

How Smart Red Teamers Use AI Today

- **Code generation:** Using Copilot and Claude to write custom tooling, BOFs, and payload loaders faster
- **Report drafting:** Having AI generate first drafts of findings that operators then refine with context and judgment
- **Technique research:** Asking LLMs to explain unfamiliar APIs, Windows internals, or protocol specifications
- **Phishing content:** Generating convincing pretext emails and landing pages tailored to specific targets
- **Log analysis:** Processing large volumes of BloodHound data, AD logs, or cloud audit trails to identify patterns

The Bottom Line

AI makes good red teamers faster, not obsolete. The operators who will thrive are the ones who learn to use AI as a force multiplier while continuing to develop the judgment, creativity, and human skills that AI cannot replicate. The operators who will struggle are the ones who relied on running tools without understanding what they do. AI raises the floor but the ceiling stays human.

Future-proof your career
Learn how to leverage AI in offensive security at career.hadess.io

Learn →

The offensive security job market is in a structurally strong position for the foreseeable future. Regulatory pressure, increasing attack sophistication, and the growing recognition that you cannot defend what you have not tested are driving sustained demand for red team professionals.

Key Market Indicators (2026)

+32%

Projected growth in offensive security roles through 2032 (BLS data, adjusted for specialization)

3,200+

Active red team job postings in the US market on any given day (LinkedIn, Indeed, CyberSeek combined)

45 days

Average time to fill a senior red team position. Employers struggle to find qualified candidates.

Demand Drivers

DRIVER	IMPACT	TIMELINE
DORA and TIBER-EU expansion	Major European financial institutions must conduct threat-led red team tests annually	Already in effect, growing through 2028
SEC cyber disclosure rules	US public companies face scrutiny on their security testing programs, driving red team investment	Ongoing since 2024
Cloud migration	Organizations moving to cloud need red teams who can test hybrid and cloud-native environments	Growing through 2030+
AI-powered attacks	As attackers use AI, organizations need red teams to simulate AI-augmented threat actors	Emerging now, major impact by 2028
Insurance requirements	Cyber insurance providers increasingly require red team assessments as a condition of coverage	Growing rapidly since 2025

Supply Constraints

The talent pipeline for red teamers is narrow. It takes 3 to 5 years of deliberate practice to become a competent operator, and most cybersecurity professionals choose defensive roles. This supply constraint is not going away. University programs do not teach red teaming. Boot camps cannot replicate the judgment that comes from years of operational experience. And the skills are perishable: an operator who stops practicing for 12 months falls behind the current state of the art.

Hottest Specializations (2026 to 2028)

Cloud Red Teaming (Azure/AWS/GCP)

Identity Attack Paths (Entra ID, Okta)

AI/ML System Red Teaming

OT/ICS Red Teaming

Container and Kubernetes Security

Supply Chain Attack Simulation

Stay ahead of the market

Get job market insights and alerts at [career.hadess.io](#)

Track Market →

Managing Burnout and Operator Fatigue

Red teaming is intellectually demanding, high-pressure work. You are constantly learning new techniques, operating under stealth constraints, and dealing with the cognitive load of maintaining operational security while making complex technical decisions. Without deliberate strategies for sustainability, burnout is not a matter of if, but when.

Burnout Risk Factors Specific to Red Teaming

FACTOR	WHY IT BURNS PEOPLE OUT	MITIGATION
Constant skill pressure	New evasion techniques, EDR updates, and attack surfaces change weekly. Falling behind feels threatening.	Dedicate specific hours for learning. Accept that you cannot know everything. Specialize.
Engagement intensity	Multi-week operations with irregular hours, especially when maintaining persistent access across time zones.	Set boundaries. Rotate operators on long engagements. Build team redundancy.
Confidentiality isolation	You cannot talk about your best work with friends or family. This creates a sense of isolation.	Build community with peers who understand. Attend conferences. Join private groups.
Imposter syndrome	The field attracts extremely skilled people. Comparing yourself to elite researchers creates self-doubt.	Focus on your own growth trajectory, not others. Document your progress.
Travel (consulting)	30% to 50% travel for on-site engagements disrupts personal routines and relationships.	Negotiate remote-first arrangements. Set maximum travel thresholds in your contract.

Sustainability Practices

- **Set learning boundaries:** You do not need to learn every new tool the day it drops. Pick 2 to 3 areas to track deeply and stay broadly aware of the rest.
- **Take real breaks:** When an engagement ends, take a day completely offline before starting the next one. Your brain needs recovery time.
- **Exercise:** This sounds generic but the research is clear. Regular physical activity is the single most effective intervention for cognitive fatigue and burnout prevention.
- **Build non-security hobbies:** You need mental space that is completely separate from work. Music, sports, cooking, whatever it is, protect that time.
- **Mentoring:** Teaching others is one of the most effective ways to combat imposter syndrome and find meaning in your work.

When to Change Something

If you notice that you dread logging into your C2 dashboard, cannot focus on reports, or feel cynical about the impact of your work, those are signals. They do not mean you need to leave the field. Sometimes the fix is changing employers, moving from consulting to internal, shifting specializations, or simply taking a two-week vacation. But ignoring the signals leads to the kind of deep burnout that takes months or years to recover from. Pay attention early.

Build a sustainable career
Get wellness resources for security professionals at career.hadess.io

Explore →

Your First 90 Days Action Plan

Whether you are entering red teaming for the first time or starting at a new organization, the first 90 days define your trajectory. This plan gives you a structured approach to build credibility, develop skills, and establish yourself as a reliable operator.

Days 1 to 30: Learn the Environment

WEEK	FOCUS	ACTIONS
Week 1	Orientation	Meet your team, understand the C2 stack, review recent engagement reports, learn the toolchain and standard operating procedures
Week 2	Lab setup	Build your personal attack VM, configure your C2 framework, set up your note-taking system (CherryTree, Obsidian, or Notion)
Week 3	Shadow operations	Observe a senior operator on an active engagement. Take notes on their workflow, OPSEC habits, and decision-making process.
Week 4	Internal practice	Run through the team's internal lab environment. Execute the standard AD attack chain. Document any gaps in your knowledge.

Days 31 to 60: Execute with Guidance

WEEK	FOCUS	ACTIONS
Week 5 to 6	First engagement	Take an assigned role on a real engagement (usually recon or initial access). Follow the operation plan. Ask questions early and often.
Week 7	Post-engagement review	Participate in the debrief. Understand what worked, what was detected, and what could be improved. Start writing your portion of the report.
Week 8	Skill development	Based on gaps you identified, start a focused learning plan. Pick one area (AD, evasion, cloud) and commit to daily practice.

Days 61 to 90: Add Value

WEEK	FOCUS	ACTIONS
Week 9 to 10	Independent execution	Run a phase of an engagement independently (with oversight). Demonstrate that you can operate reliably without hand-holding.
Week 11	Contribution	Contribute something to the team: update a playbook, improve an internal tool, share a technique you learned, or write a blog post.
Week 12	Goal setting	Meet with your lead to review your first 90 days and set goals for the next quarter. Identify the certification or skill focus for the coming months.

90-Day Success Metrics

Trust

Your lead trusts you to execute assigned tasks independently without worrying about blown operations

Credibility

Your teammates see you as reliable, curious, and honest about what you do and do not know

Impact

You have contributed at least one meaningful improvement to the team's tooling, process, or knowledge base

About HADESS

HADESS is a cybersecurity career intelligence platform built by practitioners for practitioners. We believe that career growth in cybersecurity should not be gated by access to insider knowledge. The data, frameworks, and guidance in this report reflect thousands of hours of research, interviews with hiring managers, and analysis of real market data.

What We Offer

Career Intelligence

Role-specific career guides with real salary data, skill matrices, and progression frameworks for every major cybersecurity specialization

Skills Assessment

Personalized skill gap analysis and learning recommendations based on your target role, current experience, and market demands

Job Matching

Curated job opportunities matched to your skills, experience level, and career goals with salary transparency

Our Team

HADESS was founded by cybersecurity professionals who have worked across offensive security, detection engineering, cloud security, and security leadership at organizations ranging from startups to Fortune 100 companies. We have sat on both sides of the hiring table and built this platform to solve the information asymmetry that makes cybersecurity career navigation harder than it needs to be.

Connect With Us

CHANNEL	DETAILS
Platform	career.hadess.io
Website	hadess.io
Email	career@hadess.io
LinkedIn	linkedin.com/company/hadabortsecurity
Twitter/X	@AHadess

Other Career Path Reports

- Security Analyst
- Detection Engineer
- DevSecOps Engineer
- Cloud Security Engineer
- Application Security Engineer
- Security Architect
- CISO

Each report follows the same 45-page format with role-specific salary data, skill matrices, certification roadmaps, real job postings, and actionable career guidance. Visit career.hadess.io to access the full library.

Disclaimer

Salary data and job market projections in this report are based on publicly available information from Levels.fyi, Glassdoor, LinkedIn, CyberSeek, BLS, and direct employer job postings as of Q1 2026. Individual compensation varies based on location, experience, negotiation, company size, and market conditions. This report is for informational purposes only and does not constitute financial or career advice.

Start your career journey

Join thousands of security professionals growing their careers with HADESS

Visit career.hadess.io →